

Cryptographic Security Posture Report

imap-143-starttls-weak-cert.pcapng · uploaded by user · analysed 2026-09-28 11:50:55.009374+00:00 · SHA-256 17dbeffbf0d703d58559a74ccf8bb93d...

POSTURE	RISK SCORE	SESSIONS	UPGRADES	FINDINGS	EVIDENCE
10/100	90/100	1	1	3	1.0
higher is better	CRITICAL	1 encrypted	STARTTLS / STLS	0 critical	1.0 = all visible

CRITICAL	Act now: credentials or content were exposed.	0
HIGH	Serious weakness: fix before the next mail flow that relies on it.	3
MEDIUM	Weak configuration: schedule a fix.	0
LOW	Minor or hygiene item.	0
INFO	Context, or evidence that was not visible.	0

Capture facts	
Protocols	IMAP x1
TLS versions	TLS 1.2 x1
Cipher suites	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f) x1

Prioritised findings (3)

SEVERITY	FINDING	SESSION	EVIDENCE	RECOMMENDED ACTION
HIGH	Certificate hostname does not match SNI The certificate identity did not match the observed server name.	tcp.stream.0	SNI: mail.lab.test Certificate CN: legacy.mail.test	Install a certificate containing the correct mail host in its SAN extension.
HIGH	Certificate is expired The captured leaf certificate is outside its validity period.	tcp.stream.0	Valid until: 2026-06-19 08:34:55+00:00	Replace the certificate and monitor renewal before expiry.
HIGH	Certificate public key is too small The certificate RSA key is below the commonly accepted 2048-bit minimum.	tcp.stream.0	Public key: RSA 1024 bits	Replace the certificate with RSA 2048-bit or stronger, or a suitable modern EC key.

Sessions (1)

SESSION	PROTOCOL	TLS VERSION	CIPHER SUITE	UPGRADE	RULES	ML	SCORE
tcp.stream.0	IMAP 143	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	upgraded	CRITICAL	CRITICAL	90

Recommended actions

1	Replace the certificate and monitor renewal before expiry.
2	Replace the certificate with RSA 2048-bit or stronger, or a suitable modern EC key.
3	Install a certificate containing the correct mail host in its SAN extension.
4	Enforce TLS 1.2 or TLS 1.3 and remove SSLv3/TLS 1.0/TLS 1.1.
5	Prefer ECDHE/DHE or TLS 1.3 ephemeral key exchange for forward secrecy.
6	Prefer AES-GCM or ChaCha20-Poly1305 and remove obsolete cipher suites.
7	Require valid, unexpired certificates with a complete issuer chain and matching SAN.
8	Require authentication only after a successful TLS upgrade.

What this report does and does not claim

It reports what the capture shows. Values labelled as negotiated come from the server's own handshake; values the client merely offered are labelled as offers. Missing evidence is reported as UNKNOWN or PARTIAL and never as a weakness: an unobserved certificate, a certificate encrypted inside TLS 1.3, or a truncated handshake are absences of evidence, not findings. The analysis is passive. No email content is read, stored or decrypted, and an incomplete capture cannot prove an attack - it can only show that something is worth checking. Evidence completeness for this capture: 1.0 (1.0 means every field the analyzer looks for was visible).